

HƯỚNG DẪN SỬ DỤNG

SecAudit

Ứng dụng kiểm tra An ninh mạng & ATTT
cho máy trạm Windows 10 / 11

TÓM TẮT SẢN PHẨM

SecAudit là công cụ portable một tệp .exe duy nhất, chạy quyền Administrator, hoạt động offline-first. Ứng dụng gộp 6 nhóm nghiệp vụ: thu thập thông tin hệ thống, rà soát cấu hình theo CIS, tra cứu CVE, quét LAN, phát hiện công cụ điều khiển từ xa / keylogger, và đặc biệt là phân tích nhật ký (log forensics) với 18 rule phát hiện + 8 kill-chain MITRE ATT&CK và bộ lọc khoảng thời gian.

Phát hành cho: Phòng An ninh mạng & Phòng chống tội phạm công nghệ cao
(Công an tỉnh Sơn La và các đơn vị SOC nội bộ doanh nghiệp)

Tài liệu sinh tự động ngày 21/04/2026

MỤC LỤC

1. Giới thiệu tổng quan
2. Kiến trúc & yêu cầu môi trường
3. Danh sách tính năng theo module
 - 3.1 System Info & License (Module 1)
 - 3.2 Hardening Audit — CIS checks (Module 2)
 - 3.3 Patch & CVE Audit (Module 3)
 - 3.4 LAN Scanner /24 (Module 4)
 - 3.5 Remote Access & Keylogger Detection (Module 5)
 - 3.6 Log Forensics — phân tích nhật ký (Module 6)
4. Hướng dẫn sử dụng giao diện đồ hoạ
5. Quy trình chuẩn: Log Forensics end-to-end
6. Chế độ dòng lệnh (CLI) & kịch bản WinPE offline
7. Báo cáo: HTML / PDF / DOCX / JSON
8. Bảo mật, audit log & tuân thủ pháp luật
9. Câu hỏi thường gặp & xử lý sự cố

1. GIỚI THIỆU TỔNG QUAN

SecAudit được thiết kế dành riêng cho quản trị viên hệ thống và đội SOC nội bộ — đặc biệt là các cơ quan phải đánh giá nhanh tình trạng an ninh của máy trạm Windows trong thời gian ngắn, có thể ở hiện trường (ngắt mạng), hoặc trên ổ cứng đã tháo ra thông qua USB boot WinPE.

Khác với các SIEM/EDR thương mại vận hành đám mây, SecAudit tập trung vào yêu cầu “offline-first” — toàn bộ quy tắc phát hiện, CSDL CVE, và template báo cáo được nhúng sẵn trong tệp thực thi. Cơ quan sử dụng không cần kết nối Internet, không cần cài runtime .NET bên ngoài, không phụ thuộc WebView2.

Mục tiêu chính

- Tạo báo cáo kỹ thuật + biên bản pháp lý tiếng Việt trong dưới 15 phút cho một máy trạm.
- Phát hiện brute-force, logon lạ, ransomware, keylogger, data-destruction từ nhật ký thô.
- Chấp hành Luật An ninh mạng 2018 (Điều 8) và Bộ luật Hình sự 2015 Điều 289 — mọi thao tác nhạy cảm đều được ghi vào sổ audit ký số.
- Hỗ trợ song ngữ Việt – Anh (vi-VN mặc định); hoạt động cả khi kiểm thử từ WinPE USB.

Đối tượng người dùng

- Quản trị viên / SOC analyst trong doanh nghiệp Việt Nam.
- Điều tra viên kỹ thuật số (cán bộ Phòng ANM & PCTP CNC).
- Đơn vị thanh tra công nghệ thông tin, kiểm toán nội bộ.

2. KIẾN TRÚC & YÊU CẦU MÔI TRƯỜNG

Yêu cầu hệ thống

Thành phần	Yêu cầu tối thiểu
Hệ điều hành	Windows 10 22H2 / Windows 11 22H2 trở lên (x64)
Quyền truy cập	Local Administrator (UAC elevation bắt buộc)
RAM	4 GB (khuyến nghị 8 GB khi quét nhiều .evtx)
Ổ đĩa	Tối thiểu 500 MB trống cho evidence folder
.NET runtime	Không cần — tự chứa trong single-file .exe
Network	Không bắt buộc (offline); cần khi dùng LAN Scanner hoặc đồng bộ CVE

Kiến trúc tổng thể

Ứng dụng được tổ chức theo mô hình plugin — mỗi module là một project độc lập triển khai interface `IAuditModule`. Shell WPF (`SecAudit.App`) điều phối các module thông qua dependency injection. Một dự án CLI song song (`SecAudit.Cli`) dùng chung toàn bộ lớp module nhưng bỏ WPF — phục vụ quét headless trong WinPE.

Cấu trúc giải pháp (solution)

<code>src/</code>	
<code>SecAudit.App</code>	– WPF shell, NavigationView, 6 trang
<code>SecAudit.Cli</code>	– chạy headless + chế độ <code>--offline</code>
<code>SecAudit.Core</code>	– Finding, Severity, RiskScore
<code>SecAudit.Plugins.Abstractions</code>	– <code>IAuditModule</code> , <code>ModuleMetadata</code>
<code>SecAudit.Infrastructure</code>	– wrapper WMI / Registry / Process / Net
<code>SecAudit.Security</code>	– EulaGate, AuditLog (hash-chain + ECDSA)
<code>SecAudit.Reporting</code>	– HTML + PDF + DOCX + JSON writers
<code>SecAudit.Cve.Pipeline</code>	– NVD downloader + CPE matcher
<code>SecAudit.Modules.SystemInfo</code>	– Module 1
<code>SecAudit.Modules.Hardening</code>	– Module 2 (12 CIS checks)
<code>SecAudit.Modules.PatchCve</code>	– Module 3
<code>SecAudit.Modules.LanScanner</code>	– Module 4
<code>SecAudit.Modules.RemoteAccess</code>	– Module 5
<code>SecAudit.Modules.LogForensics</code>	– Module 6 (18 rule + 8 chain)
<code>tools/SecAudit.DocGen</code>	– sinh tài liệu này

Cây dữ liệu runtime (tạo lần đầu chạy)

%LOCALAPPDATA%\SecAudit\	
cve\cve.db	– CSDL NVD offline
forensics\<session-id>\	– evidence folder mặc định
originals\	– bản sao tệp log
findings.json	– kết quả chi tiết
manifest.json	– chain-of-custody SHA-256
logs\audit-YYYYMMDD.log	– sổ audit JSONL ký ECDSA
eula-accepted	– marker chấp thuận EULA

3. DANH SÁCH TÍNH NĂNG THEO MODULE

SecAudit hiện có 6 module hoạt động độc lập, có thể chạy riêng rẽ hoặc chạy cả bộ. Mỗi module sản sinh một tập hợp Finding với phân loại (category), mức độ nghiêm trọng (severity) và phần evidence rõ ràng phục vụ kết luận giám định.

3.1 Module 1 – System Info & License

Thu thập thông tin nhận dạng máy và tình trạng bản quyền phần mềm:

- ◆ HardwareInventory – CPU, RAM, ổ đĩa, BIOS serial (WMI).
- ◆ LicenseChecker – trạng thái kích hoạt Windows (Retail/KMS/MAK, Genuine).
- ◆ OfficeKmsPicoDetector – phát hiện dấu vết KMSpico và kích hoạt Office bất thường.
- ◆ SoftwareInventory – liệt kê phần mềm đã cài (HKLM\Uninstall + HKCU + WOW6432Node).

Kết quả xuất vào SystemInventory chia sẻ để Hardening và PatchCve tái sử dụng.

3.2 Module 2 – Hardening Audit (CIS-style)

Gồm 12 check theo CIS Benchmark Microsoft Windows:

- ◆ UacCheck – User Account Control bật.
- ◆ SmbV1Check – SMB v1 đã tắt (MS17-010 surface).
- ◆ RdpNlaCheck – Network Level Authentication cho RDP.
- ◆ FirewallCheck – Windows Defender Firewall bật mọi profile.
- ◆ DefenderCheck – Defender real-time + signature up-to-date.
- ◆ BitLockerCheck – Mã hoá ổ hệ thống.
- ◆ GuestAccountCheck – Tài khoản Guest đã bị vô hiệu hoá.
- ◆ AutoRunCheck – Autostart trong HKLM Run / RunOnce sạch.
- ◆ LsaRunAsPplCheck – LSA Protected Process Light bật (chặn dump LSASS).
- ◆ PowerShellLoggingCheck – Script Block + Transcription logging bật.
- ◆ CredentialGuardCheck – VBS Credential Guard bật.
- ◆ HardeningModule – orchestrator chạy tất cả song song.

Mỗi check trả về remediation cụ thể để bộ phận CNTT xử lý.

3.3 Module 3 – Patch & CVE Audit (offline)

Đối chiếu inventory phần mềm đã cài với CSDL CVE offline:

- ◆ FastPathRules – 6 CVE nghiêm trọng: MS17-010, PrintNightmare, SMBGhost, Follina, BlueKeep, PetitPotam (không cần NVD).
- ◆ CveDatabase – SQLite NVD tại %LOCALAPPDATA%\SecAudit\cve\cve.db.
- ◆ Matcher dùng NuGet.Versioning so sánh khoảng version half-open.
- ◆ Cảnh báo khi CSDL cũ hơn 30 ngày (meta.last_sync).

Tìm ra các KB bị thiếu cho build Windows hiện tại.

3.4 Module 4 – LAN Scanner /24

Khám phá và đánh giá rủi ro các host cùng mạng nội bộ – pure managed, không phụ thuộc Npcap:

- ◆ SubnetDiscovery – phát hiện /24 từ NetworkInterface cục bộ.
- ◆ HostDiscovery – ARP (iphlpapi.SendARP) + ICMP ping song song.
- ◆ PortScanner – TCP connect top 1000 port, timeout 500 ms, semaphore 256.
- ◆ SmbV1Probe – gửi gói SMB1 negotiate để fingerprint server SMBv1.
- ◆ RdpNlaProbe – X.224 + rdpNegReq để phát hiện RDP không NLA.

Phạm vi quét tuân theo CIDR do người dùng cấu hình; không động vào host ngoài subnet.

3.5 Module 5 – Remote Access & Keylogger Detection

Phát hiện 5 nhóm tín hiệu persistence / RAT – dựa trên registry, file, scheduled task, WMI (không chạy memory scan để tránh AV false positive):

- ◆ PersistenceDetector – HKLM Run / RunOnce bất thường.
- ◆ WmiPersistenceDetector – __EventFilter / ActiveScriptEventConsumer / Binding (APT29 signature).
- ◆ ServicesHiveDetector – dịch vụ Windows trở path nghi vấn (%TEMP%, %APPDATA%).
- ◆ ScheduledTasksXmlDetector – Tasks XML có action -EncodedCommand, DownloadString.
- ◆ RemoteAccessToolDetector – TeamViewer, AnyDesk, RustDesk, VNC, QuickAssist.

Module này nhiều false positive (admin tool hợp pháp), luôn đi kèm evidence để xác minh.

3.6 Module 6 – Log Forensics (chi tiết)

Đây là module trung tâm của SecAudit – phân tích nhật ký Windows/Linux/Web để tái tạo dòng sự kiện một cuộc tấn công. Module không chạy mặc định khi người dùng nhấn Dashboard → nó đòi hỏi người phân tích cấu hình nguồn log cụ thể thông qua trang "Log Forensics" (xem Chương 5).

8 Parser được hỗ trợ

Parser	Định dạng
WindowsEvtxParser	.evtx (Windows Event Log nhị phân)
LinuxAuthLogParser	/var/log/auth.log
LinuxSyslogParser	/var/log/syslog
IisW3cLogParser	IIS W3C extended format
NginxAccessLogParser	Nginx combined/main
ApacheErrorLogParser	Apache error.log
BashHistoryParser	~/.bash_history
SysmonXmlParser	Sysmon event 1/3/7/8/10/11/13/22

18 rule phát hiện

Nhóm Security log (9 rule) + nhóm Sysmon (10 rule):

Rule ID	Phát hiện
FOR-BRUTE	≥10 logon thất bại cùng user/IP trong 5 phút
FOR-UNKNOWN	Logon bởi user ngoài whitelist baseline
FOR-SVC	Dịch vụ Windows lạ / path user-writable
FOR-CLEAR	Event log bị xóa / rsyslogd restart marker
FOR-SCAN	Scanner fingerprint (sqlmap, nikto, URL fan-out)
FOR-PRIVESC	sudo ... bash -p, su sau auth fail, token manipulation
FOR-KEYLOGGER	Lệnh cài logkeys / debugger hook
FOR-RANSOM	Pattern mass-write file extension + shadow delete
FOR-WIPE	rm -rf --no-preserve-root, dd zero, vssadmin delete

Rule ID	Phát hiện
SYSMON-LSASS	Process truy cập vào LSASS (mimikatz surface)
SYSMON-INJECT	CreateRemoteThread – process injection
SYSMON-SIDELOAD	DLL sideload từ thư mục user-writable
SYSMON-PSENC	PowerShell -EncodedCommand / -enc / IEX DownloadString
SYSMON-PIPE	Named-pipe Cobalt Strike IoC (\\.pipe\\MSSE-...)
SYSMON-OFFICE-CHAIN	WINWORD/EXCEL sinh cmd/powershell con
SYSMON-WMI	WMI Event Subscription được đăng ký mới
SYSMON-SC-CREATE	sc.exe create từ path đáng ngờ
SYSMON-LOLBIN-DL	certutil/bitsadmin/mshta tải file từ HTTP
SYSMON-DEFENDER-OFF	Defender / EDR bị tắt / add-exclusion

8 Kill-chain MITRE ATT&CK (correlation)

Correlation engine theo dõi tuần tự các finding và phát ra một finding nghiêm trọng hơn khi nhiều rule cùng fire theo đúng trình tự + trong cửa sổ thời gian. Pivot là Finding.Asset (host / user / process).

Chain ID	Kịch bản	Window
CHAIN-PHISH-EXEC	Office → PS enc → LOLBin download	5 phút
CHAIN-RANSOMWARE	Defender off → mass encrypt → xóa shadow	10 phút
CHAIN-CREDACCESS	LOLBin/PS → LSASS access/inject	10 phút
CHAIN-PERSIST-WMI	PS/LOLBin → đăng ký WMI Event Subscription	10 phút
CHAIN-PERSIST-SVC	PS/LOLBin → sc create dịch vụ từ user path	10 phút
CHAIN-LATERAL	Unknown/brute logon → privesc/ LSASS	15 phút
CHAIN-INGRESS-C2	LOLBin → DLL sideload/inject → named pipe C2	10 phút
CHAIN-DEFEVASION	Defender off → xóa event log	30 phút

Bộ lọc khoảng thời gian (time window filter)

Từ phiên bản này, Log Forensics cho phép giới hạn phạm vi phân tích theo thời gian — phù hợp kịch bản phản ứng sự cố khi analyst đã biết khung giờ xảy ra. Engine bỏ qua các bản ghi có timestamp ngoài khoảng [FromUtc, ToUtc], tiết kiệm CPU đáng kể khi nhật ký dài 30 ngày nhưng chỉ quan tâm 2 giờ.

- Preset sẵn: 1 giờ qua / 24 giờ qua / 7 ngày qua / 30 ngày qua / Xoá.
- Chỉnh tay: DatePicker + ô HH:mm cho mốc "Từ" và "Đến" (giờ local).
- Lọc áp dụng sau parse → an toàn với mọi định dạng (evtx, syslog, IIS...).
- Ghi vào audit log: from_utc, to_utc, skipped_by_window để kiểm toán.

4. HƯỚNG DẪN SỬ DỤNG GIAO DIỆN ĐỒ HOẠ

4.1 Khởi chạy lần đầu

1. Copy SecAudit.exe sang máy cần kiểm tra (USB / chia sẻ nội bộ).
2. Click chuột phải → Run as administrator. UAC sẽ hỏi — chọn Yes.
3. Hộp thoại EULA hiện ra lần đầu: đánh 2 checkbox + gõ chuỗi I AM AUTHORIZED (bắt buộc) để xác nhận có ủy quyền kiểm tra hợp pháp.
4. Sau khi chấp thuận, shell chính hiện ra với NavigationView bên trái.

4.2 Cấu trúc giao diện

- Dashboard — khởi chạy Full Audit 5 module (System/Hardening/Patch/LAN/Remote); hiển thị tổng rủi ro, biểu đồ mức độ, lưới findings, nút xuất báo cáo.
- Log Forensics — trang chuyên biệt để cấu hình và chạy Module 6.
- Settings — nhập metadata báo cáo (tên đơn vị, người kiểm tra, khách hàng).
- Help — tài liệu tham chiếu nhanh.

4.3 Quy trình Dashboard (Full Audit)

1. Nhấn "Run Full Audit" — 5 module chạy tuần tự.
2. Theo dõi ProgressBar + đếm findings trên từng dòng module.
3. Khi hoàn tất, lưới Findings hiển thị kết quả đã sắp theo severity.
4. Nhấn "Xuất báo cáo" → chọn thư mục đích → 4 tệp sinh ra đồng thời (HTML/PDF/DOCX/JSON).
5. Mở thư mục evidence để xem manifest chain-of-custody.

4.4 Các điều khiển chung

Thao tác	Hiệu ứng
Bắt đầu phân tích	Khởi chạy module tương ứng với cấu hình hiện tại
Hủy	Gửi CancellationToken — module dừng ở điểm an toàn
Mở thư mục bằng chứng	Mở Explorer trở vào evidence folder của phiên
Xuất báo cáo	Sinh đồng thời 4 định dạng trong thư mục lưu trữ

5. QUY TRÌNH CHUẨN: LOG FORENSICS END-TO-END

Chương này mô tả chuẩn quy trình phân tích một máy nghi bị xâm nhập. Giả định analyst đã thu thập các .evtx và /var/log vào thư mục D:\Evidence\Case-2026-042.

Bước 1 — Chọn nguồn log

- Tab "Thư mục / tệp local" — trở vào D:\Evidence\Case-2026-042 và bật "Quét đệ quy".
- Tab "Windows Event Log" — nhập channel Security/System để quét live (cần admin).
- Tab "SSH / SFTP remote" — nhập host + username + khoá riêng; cấu hình RemotePath=/var/log.

Bước 2 — Baseline & CIDR nội bộ

- User whitelist: nhập chính xác các tài khoản được phép (vd: admin,root,dev). Bất kỳ tên đăng nhập khác sẽ bị flag là logon lạ.
- Internal CIDR: mặc định 192.168.0.0/16, 10.0.0.0/8, 172.16.0.0/12 — sửa nếu cần.
- Evidence folder: để trống để dùng %LOCALAPPDATA%\SecAudit\forensics; hoặc chọn một thư mục riêng (vd D:\Forensics\Case-2026-042).

Bước 3 — Giới hạn khoảng thời gian (NEW)

Đây là bước quan trọng nhất để rút ngắn thời gian phân tích. Bật checkbox "Giới hạn khoảng thời gian" ở góc phải Card. Có 4 preset nhanh hoặc nhập tay:

1. Preset: nhấn 1 giờ qua / 24 giờ qua / 7 ngày qua / 30 ngày qua theo mức chuẩn IR.
2. Nhập tay: chọn DatePicker cho ngày; ô bên cạnh gõ giờ phút dạng HH:mm (vd 14:30).
3. Hệ thống quy đổi giờ local → UTC, validate Từ ≤ Đến.
4. Engine sẽ loại bỏ bản ghi có timestamp ngoài khoảng ngay sau parse.

Bước 4 — Bắt đầu phân tích

1. Nhấn nút "Bắt đầu phân tích" (màu xanh, bên trái hàng nút điều khiển).
2. Theo dõi ProgressBar và 2 bộ đếm: Files (số tệp đã xử lý) và Records (số bản ghi đã parse).
3. Trường "Evidence:" hiển thị đường dẫn phiên đang chạy — bản sao log gốc được lưu tại đây.
4. Có thể nhấn "Huỷ" bất kỳ lúc nào — tiến trình dừng an toàn, báo cáo vẫn xuất được.

Bước 5 — Đọc kết quả

- Tab "Phát hiện" — DataGrid cột Severity / Category / Title / Asset / Evidence.

- Tab "Chain-of-custody" — danh sách tệp log kèm SHA-256 làm bằng chứng pháp lý.
- Kill-chain finding hiển thị category = log-forensics.kill-chain, severity = Critical; evidence liệt kê đầy đủ các stage theo thứ tự thời gian.

Bước 6 — Xuất báo cáo

Nhấn "Xuất báo cáo (PDF/DOCX/HTML/JSON)". Hộp thoại ReportMetadata yêu cầu nhập:

- Tên đơn vị kiểm tra (ví dụ: Công an tỉnh Sơn La).
- Tên người thực hiện + chức vụ.
- Tên khách hàng / chủ thể bị kiểm tra.
- Địa điểm + số hiệu biên bản.

Báo cáo PDF theo mẫu "BIÊN BẢN GHI NHẬN" — format chuẩn cho hồ sơ pháp lý. DOCX cho phép chỉnh sửa thêm. HTML mở nhanh trong trình duyệt. JSON dùng để tích hợp ngược vào SIEM hoặc case-management.

6. CHẾ ĐỘ DÒNG LỆNH (CLI) & KỊCH BẢN WINPE OFFLINE

SecAudit.Cli là binary song song với SecAudit.App — dùng chung toàn bộ module nhưng không phụ thuộc WPF, chạy được trên Windows PE / Hiren's BootCD PE / Gandalf's Win10 PE. Phù hợp kịch bản điều tra máy đã tắt: boot USB WinPE, gắn ổ cứng Windows của máy mục tiêu, chạy SecAudit.Cli.exe --offline D:\

Cú pháp

```
SecAudit.Cli.exe [--offline <drive>] [--output <dir>] [--asset <name>]
                [--formats <csv>] [--quiet] [-h|--help]
```

Cờ được hỗ trợ

Cờ	Ý nghĩa
--offline <drive>	Quét ổ Windows đã được mount (vd D:\). Tự đọc winevt\Logs; chỉ chạy PatchCve, RemoteAccess, LogForensics.
--output <dir>	Thư mục ghi báo cáo (mặc định thư mục hiện tại).
--asset <name>	Ghi đè tên tài sản trong báo cáo (mặc định %COMPUTERNAME% hoặc <drive>-OFFLINE).
--formats <csv>	Tập con trong {html,pdf,json,docx} (mặc định cả 4).
--quiet	Ẩn progress; chỉ in lỗi.
-h, --help	Hiển thị hướng dẫn nhanh.

Mã trả về (exit code)

Code	Ý nghĩa
0	Thành công — báo cáo đã sinh.
2	Module báo lỗi nhưng tiếp tục chạy được.
3	Lỗi không xử lý được (unhandled exception).
64	Cờ sai — kiểm tra lại cú pháp.

Ví dụ thực tế

```
# Quét live máy đang chạy, chỉ xuất PDF + JSON:
SecAudit.Cli.exe --formats pdf,json --output D:\Reports

# Quét offline ổ Windows tháo ra, gắn ở D:\, tên asset = DESKTOP-KT07:
SecAudit.Cli.exe --offline D:\ --asset DESKTOP-KT07 --output E:\Case-042

# Dùng trong script PowerShell, ẩn progress:
& "C:\Tools\SecAudit.Cli.exe" --offline F:\ --quiet --formats json
if ($LASTEXITCODE -ne 0) { Write-Error "Scan failed" }
```

Kịch bản WinPE (USB điều tra)

1. Boot máy mục tiêu từ USB WinPE (Hiren's / Gandalf's).
2. Trong WinPE, gắn ổ cứng Windows → thường là D:\ hoặc F:\
3. Chạy SecAudit.Cli.exe từ USB khác (chỉ 1 tệp, không cần cài đặt).
4. Kết quả ghi ra thư mục --output; copy báo cáo về USB trả lại người yêu cầu.
5. Máy mục tiêu KHÔNG thay đổi gì — ổ đĩa chỉ được đọc.

7. BÁO CÁO: HTML / PDF / DOCX / JSON

Định dạng	Writer	Dùng khi nào
HTML	HtmlReportWriter	Xem nhanh trên trình duyệt; chia sẻ nội bộ.
PDF	PdfReportWriter (QuestPDF)	Biên bản pháp lý — có chữ ký đóng dấu.
DOCX	DocxReportWriter (OpenXml)	Cần chỉnh sửa thêm trước khi nộp.
JSON	JsonReportWriter	Nhập vào SIEM / case management / backup máy.

Nội dung tiêu biểu một báo cáo

- Trang bìa: tên đơn vị, ngày giờ, tên máy, số hiệu biên bản.
- Tóm tắt điều hành: risk score tổng, biểu đồ pie severity, danh sách vấn đề nổi bật.
- Thông tin thiết bị: CPU, RAM, OS, BIOS serial, MAC, IP.
- Danh sách findings nhóm theo module, màu severity.
- Phụ lục: evidence dài, manifest chain-of-custody SHA-256.
- Phần kết luận / ký tên theo mẫu biên bản công tác.

Vị trí lưu trữ

```
<output-dir>\
  report-YYYYMMDD-HHmss.html
  report-YYYYMMDD-HHmss.pdf
  report-YYYYMMDD-HHmss.docx
  report-YYYYMMDD-HHmss.json
  evidence\manifest.json           (nếu có log forensics)
  evidence\originals\*.log.bak    (bản sao log gốc)
```


8. BẢO MẬT, AUDIT LOG & TUÂN THỦ PHÁP LUẬT

8.1 EULA Gate

Ngay khi khởi động, SecAudit hiển thị hộp thoại End-User License Agreement bằng tiếng Việt và Anh, viện dẫn Luật An ninh mạng 2018 Điều 8 + Bộ luật Hình sự 2015 Điều 289 (xâm nhập trái phép hệ thống thông tin). Người dùng buộc phải đánh 2 checkbox và gõ chuỗi xác nhận "I AM AUTHORIZED" để qua gate. Tất cả sự kiện chấp thuận được ghi vào audit log kèm SID, tên máy, dấu thời gian.

8.2 Audit log ký số

Mọi thao tác nhạy cảm ghi vào %LOCALAPPDATA%\SecAudit\logs\audit-YYYYMMDD.log (JSONL append-only). Mỗi record có prev_hash SHA-256 tạo hash chain + chữ ký ECDSA-P256. Khóa riêng được sinh lần đầu, bảo vệ bằng DPAPI LocalMachine scope, lưu tại %LOCALAPPDATA%\SecAudit\keys\audit.key. Khóa công khai nhúng trong binary.

- Sự kiện bắt buộc log: start/stop mỗi module, EULA accepted, từ_utc / đến_utc của forensics, xuất báo cáo, truy cập evidence folder.
- Sổ audit hiển thị được bằng công cụ verify đi kèm — phát hiện mọi chỉnh sửa trái phép.

8.3 Integrity check khởi động

Khi chạy, SecAudit tự kiểm SHA-256 của tệp .exe so với hash nhúng lúc publish. Nếu mismatch (ngghi bị sửa đổi), các module nhạy cảm bị tắt, banner đỏ cảnh báo trên shell; chỉ cho phép chạy module read-only.

8.4 Chain-of-custody log forensics

Mỗi phiên Log Forensics sinh manifest.json liệt kê từng tệp log gốc đã quét với SHA-256, kích thước, đường dẫn gốc, và hash chain. Tài liệu này đính kèm báo cáo giám định để tòa án xác minh tính toàn vẹn bằng chứng.

8.5 Lưu ý quan trọng — pháp lý



Chỉ sử dụng SecAudit trên máy tính và hệ thống mạng mà bạn có quyền truy cập hợp pháp. Kiểm thử mật khẩu yếu không được phép thực hiện trên tài khoản domain. Kịch bản LAN Scanner có opt-in probe default-creds — chỉ bật trên phòng lab nội bộ với biên bản ủy quyền kiểm thử. Vi phạm có thể cấu thành tội danh theo BLHS Điều 289.

9. CÂU HỎI THƯỜNG GẶP & XỬ LÝ SỰ CỐ

Q. Windows Defender báo đỏ khi chạy SecAudit.exe

SecAudit có chứa code đọc registry, WMI, và P/Invoke iphlapi — dễ bị heuristic nhầm với công cụ tấn công. Bản chính thức được ký OV code-signing và gửi Microsoft WDSI sau mỗi release. Nếu dùng trong môi trường doanh nghiệp, thêm exclusion cho đường dẫn tệp. Tuyệt đối KHÔNG dùng bản không ký.

Q. Không thấy nút "Bắt đầu phân tích" trên trang Log Forensics

Đã sửa trong phiên bản hiện tại — layout được cấu trúc lại với DockPanel: phần cấu hình có thể cuộn, hàng nút + progress + findings luôn hiển thị. Nếu vẫn không thấy, hãy phóng to cửa sổ lên $\geq 1280 \times 720$ hoặc cuộn phần cấu hình lên trên.

Q. Thời gian quét quá lâu khi log dài 30 ngày

Bật checkbox "Giới hạn khoảng thời gian" trên trang Log Forensics. Dùng preset "24 giờ qua" hoặc nhập khung giờ bạn nghi xảy ra sự cố. Engine sẽ lọc bỏ bản ghi ngoài khoảng NGAY SAU khi parse, tiết kiệm 90%+ CPU trong phần analysis.

Q. CSDL CVE hiển thị cảnh báo "cũ hơn 30 ngày"

Click nút "Update CVE database" trong module Patch/CVE để đồng bộ NVD (cần Internet). Trong môi trường air-gap, tải thủ công NVD JSON feed và thay thế %LOCALAPPDATA%\SecAudit\cve\cve.db bằng file do đội security center cấp.

Q. Làm sao verify một báo cáo PDF không bị sửa đổi?

Mỗi báo cáo đi kèm SHA-256 in ở chân trang và một entry tương ứng trong audit log đã ký ECDSA. Chạy công cụ verify đi kèm để so sánh hash. Ngoài ra chain-of-custody manifest.json chứa hash các tệp log gốc — không thể bị chỉnh sửa mà không phát hiện.

Q. Kill-chain finding không xuất hiện dù các rule thành phần đều fire

Kiểm tra ba điều kiện: (1) các finding phải có cùng pivot (cùng Asset, vd cùng host:TEST-01); (2) tuân tự đúng thứ tự các stage của chain; (3) toàn bộ trong cửa sổ thời gian của chain (xem bảng 8 chain). Nếu out-of-order, engine sẽ reset tiến độ khi thấy stage 0 mới.

Q. SSH remote báo lỗi authentication

Ưu tiên xác thực khoá riêng (Private key) hơn password. Nếu khoá có passphrase, nhập vào ô SshPrivateKeyPassphrase (ẩn trong UI). Đảm bảo user có quyền đọc /var/log/auth.log (nhóm adm trên Ubuntu, nhóm systemd-journal trên RHEL).

Q. Ổ đĩa offline không nhận diện được Windows

--offline yêu cầu cấu trúc Windows chuẩn: <drive>\Windows\System32\config\SOFTWARE và <drive>\Windows\System32\winevt\Logs. Nếu đĩa bị mã hoá BitLocker, phải unlock trước trong WinPE (manage-bde -unlock) rồi mới chạy SecAudit.Cli.

— HẾT —

Liên hệ hỗ trợ: duonggiabao.anm@gmail.com